Security-1

Basit Güvenlik Bileşenleri (CIA)

1. Gizlilik
    a. Bilgi ve bilgi kaynaklarının gizlenmesi ve sadece yetkisi olanların görebilmesi.
2. Bütünlük
    a. Veri kaynağının bütünlüğü
    b. Veri bütünlüğü
    c. Kaynak bütünlüğü
    d. Verileri değiştirmeye karşı koruma
    e. Bütünlük durumunu bildirme
3. Kullanılabilirlik
    a. İstenilen bilgiyi ya da kaynağı kullanabilme yeteneği
    b. Kullanılabilirliği engelleme girişmleri, hizmet reddi saldırıları olarak tanımlanır.

Güvenliğe Karşı Tehditler

- Bir tehdit olması için gerçekten ihlalin gerçekleşmiş olması gerekmez.

Tehditlerin 4 Ana Sınıfları

1. İfşa: Bilgilere izinsiz erişim.
2. Aldatma: Sahte verilerin kabulü.
3. Bozulma: İşleyişin kesintiye uğratılması ya da engellenmesi.
4. Gasp Etmek: Sistemin bazı kısımlarının yetkisiz kullanılması.

Casusluk

- Yetkisiz bilgi erşimi bir ifşa biçimidir.
- Pasif bir tehdit tipidir.
- İletişim dinleme, dosya ve sistem bilgilerine göz atmak örnek verilebilir.

Değişiklik

- Casusluğun aksine aktif bir saldırıdır.
- 3 ana sınıfı kapsar.
- Amaç aldatmak olabilir.
- Saldırgan aradaki mesajları okur ve değiştirilmiş versiyonunu alıcıya gönderir.

Maskeleme & Taklit Etme

- Birinin başka birini taklit etmesi hem aldatma hem de gaspın bir biçimidir.
- Kurbanı başka biri olduğuna inandırır.
- Delegasyon izin verilen bir maskeleme biçimidir.
    - Bir kullanıcı başka bir kullanıcıya işlemleri yerine getirmesi için yetki verir.

Kökeni Reddetme

- Bir aldatma biçimidir.
- Bir varlığın bir şeyi yarattığını veya gönderdiğini yalanlamasıdır.

Alma Reddi

- Bir varlığın bir bilgi veya mesajı aldığını yalan biçimde reddetmesidir.
- Aldatma tipinde bir saldırıdır.

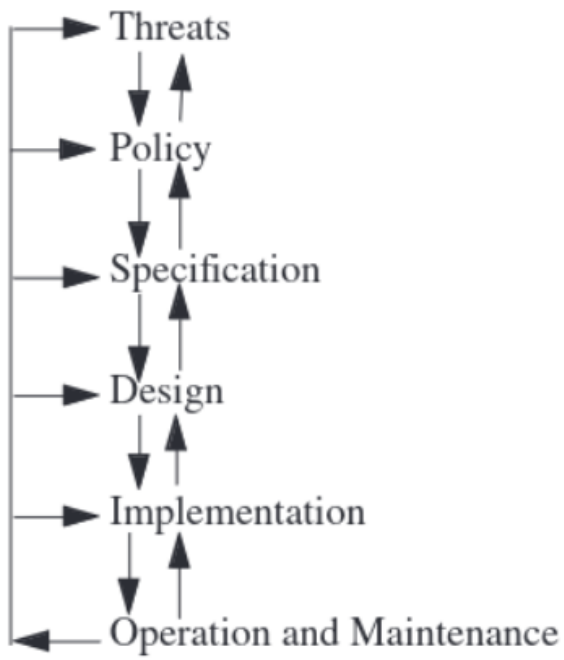
Gecikme

- Bir hizmetin geçici olarak engellenmesi bir gasp biçimidir.
- Aldatma da rol oynayabilir.
    - Bir senaryoda A server'inden yetkilendirme mesajı bekleyen kişinin mesajı geciktirildiğini varsayalım, bu kişi B server'inden sorgu yaptığında B server'i gibi davranan bir saldırgan tarafından yanlış bilgilendirilebilir. (Saldırganın A server'i gibi davranamadığı düşünülmelidir.)

Hizmet Reddi

- Bir gasp biçimidir.
- Genelde aldatmak için diğer mekanizmalarla birlikte kullanılır.
- Kaynaktayken sunucunun görevini yerine getirmesi için gerekli verileri almasını engeller.
- Hedefteyse sunucudan giden mesajları engeller.
- Sunucudan ya da istemciden (veya her ikisinden) gelen mesajları yok eder.

Güvenli Yaşam Döngüsü



- İnsan sorunları döngünün her aşamasına nüfuz eder ve her düğüm, birbirini geri besler.

1. Tehditleri Belirlemek
2. Bir Politika Oluşturmak
    a. Güvenlik standartlarını belirlemek için oluşturulur
3. Politikadan Şartname Oluşturmak
    a. Politikanın nasıl uygulanacağının detaylarıdır.
    b. Teknik bilgi içerir.
4. Tasarı Geliştime
5. Tasarımı Uygulama

Operasyonel Sorunlar

Maliyet-Fayda Analizi

- Örneğin çalışanların maaş bilgilerini ele alalım;
    - Eğer veritabanında değişiklikler yapılırsa bu mâli kayba yol açar ve mümkün olan en büyük bütünlük mekanızmasını gerektirir.
    - Ama eğer kopyalar dağıtırsak ve bu kopyalarda sorun çıkarsa veritabanında bir değişiklik olmadığından mâli kayıp ortadan kalkar.

Risk Analizi

- Bir varlığın hangi düzeyde korunması gerektiğini belirlemek için o varlık üzerindeki potansiyel tehditleri ve gerçekleşme olasılıklarını analiz eder.

Yasalar ve Gelenekler

- Yasalar teknolojinin kullanılabilirliğini kısıtlar.

İnsan Sorunları

- Güvenlik sistmelerinin kalbi insanlardır.
- İnsan müdahalesiyle birçok teknolojik güvenliği aşabilisiniz.
- Birçok başarılı izinsiz girişimin sebebi sosyal mühendislikten kaynaklanmaktadır.

Temel Kriptografi

Klasik kripto sistemleri (tek anahtarlı veya simetrik kripto sistemleri)

- Şifrelemek ve bu şifreyi çözmek için aynı anahtarı kullanan kripto sistemleridir.

Transpozisyon Şifreleri

- Karakterleri yeniden düzenler, anahtar bir permütasyon fonksiyonudur.

```
Example: “HELLO, WORLD” ->

        HLOOL
        ELWRD
+
————————————————————————
        “HLOOLELWRD.”
```

Sezar Şifresi

- Buradan soru gelmez.

Vigenère Tablosu

- Vigenère tablosu her satırda ilk harfin sona kaydırılmasıyla oluşur.

- Öncelikle bizim şifreleyeceğimiz metne ve bir anahtara ihtiyacımız var.
- Şifreleyeceğimiz kelime HELLO olsun, anahtar da KEY olsun.
- Anahtarı şifremiz kadar uzatırız, yani KEYKE olur.
- Harflerin Vigenère tablosuna göre kesiştiği yerlerdeki harflerle yeni şifre oluştururuz.
- Çözmek içinse satırda veya sütunda anahtardaki karakterin satırında veya sütununda şifredeki karakteri buluruz, bulduğumuz karakterin sütununda veya satırında hangi karakter varsa o karakter bizim metnimize aittir.
- Tek seferlik Şifre: Eğer anahtar metin kadar uzunsa, yanı KEYKE kadar uzatmaya gerek yoksa (örnekteki gibi) buna tek seferlik şifre denir.

	A	*B*	*C*	*D*	*E*	*F*	*G*	*H*	*I*	*J*	*K*	*L*	*M*
A	A	B	C	D	E	F	G	H	I	J	K	L	M
B	B	C	D	E	F	G	H	I	J	K	L	M	N
C	C	D	E	F	G	H	I	J	K	L	M	N	O
D	D	E	F	G	H	I	J	K	L	M	N	O	P
E	E	F	G	H	I	J	K	L	M	N	O	P	Q
F	F	G	H	I	J	K	L	M	N	O	P	Q	R
G	G	H	I	J	K	L	M	N	O	P	Q	R	S

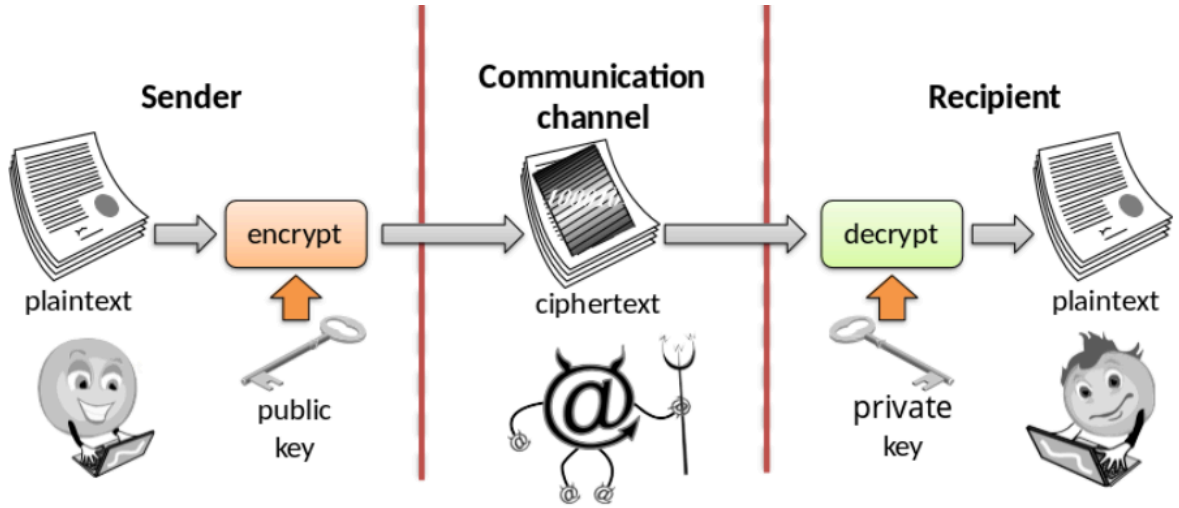
EXAMPLE: The first line of a limerick is enciphered using the key "BENCH," as follows.

Key	B ENCHBENC HBENC HBENCH BENCHBENCH
Plaintext	A LIMERICK PACKS LAUGHS ANATOMICAL
Ciphertext	B PVOLSMPM WBGXU SBYTJZ BRNVVNMPCS

Public Key Kriptografisi

- Şifreleme ve şifre çözme anahtarları olmak üzere 2 farklı anahtardan oluşur
  - Public Key (Şifreleme anahtarı) herkes tarafından bilinir.
  - Private Key (Şifre Çözme Anahtarı) sadece sahibi tarafından bilinir.

1. Gönderici metni public key ile şifreler
2. Alıcı şifreli metni private key ile çözer ve orijinal metne ulaşır.



- RSA şifrelemesi örnek verilebilir.

Kriptografik Kontrol Toplamları (Checksum Fonksiyonu/Hash'lama)

- Gönderilen ve alınan mesajın aynı olduğundan emin olmak için kullanılır.

1. Gönderici n bitlik bir mesaj yazar ve bu mesajdan n bitten daha az olan bir dizi çekecek şekilde fonksiyon yazar.
2. Fonksiyonu, fonksiyon sonucunu ve mesajı alıcıya gönderir.
3. Alıcı fonksiyonu kullanarak mesajı test eder ve eğer sonuç gönderilenle aynıysa mesajların aynı olduğu sonucuna varılır.

- Bu checksum fonksiyonu;
  - Hesaplaması ve sonucu alması kolaydır.
  - Fonksiyonu tersine çevirip işlem yapmak imkansızdır.
  - Farklı değerlerin aynı sonucu vermesi imkansızdır. (Çarpmışma bulmak imkansızdır.)

Anahtar Yönetimi

Oturum ve Değişim Anahtarları

Oturum Anahtarı

- Doğrudan bir iletişime ait olan kriptografik bir anahtardır.
- Genellikle tek bir oturum için geçerlidir ve oturum sonlandırıldığında geçerliliğini yitirir.
- Kısa süreli olduğundan, eğer anahtar elegeçirilirse sadece o oturum tehlikeye girmiş olur.

Değişim Anahtarı

- Oturuma dahil olan taraflardan birine ait olan kriptografik bir anahtardır.
- Genellikle daha uzun ömürlüdür ve bir oturumdan daha fazlasını kapsar.
- Anahtar saklama, yönetim, değişimi ve dijital imza gibi durumlarda kullanılabilir.

HTTPS

- HTTPS iletişimi şifrelemek için şifreleme protokolü kullanılır.
- Protokole Transport Layer Security (TLS) adı verilir, eskiden Secure Sockets Layer (SSL) olarak biliniyordu.
- HTTPS, belirli bir sağlayıcının söylediği kişi olduğunu doğrulayan TLS/SSL sertifikalarının iletilmesine dayanarak gerçekleşir.

- Private Key: Bu anahtar sunucu admini tarafından kontrol edilir ve gizli tutulur.
- Public Key: Bu anahtarı sunucuyla etkileşim kurmak isteyen herkes kullanabilir.

Açık Yetkilendirme

- Bir tür delegasyondur.
- Genelde kullanıcıların bir siteye başka bir sitedeki yetkilerini vermeleridir, Yetkilerini verirler ancak şifrelerini vermezler
- Discord sunucularında botlara yetki verilmesi veya saat uygulamasının spotify yetkisi istemesi örnek verilebilir.

OpenID Kimlik Doğrulaması

- Authenticator uygulamalarının yaptığı şeydir.